LABORATUVAR 5 · MAKİNEYE ÖZEL SÜRÜM · DRACHEN 2128 HYPER CNC ROUTER

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad: Emirhan Bayrak | Grup: Gündüz | Tarih: 06.11.2026

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	Component X (CNC kontrol yazılımı / hareket kartı firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1 **Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)**

- **Bileşen var mı?** Makinenin SBOM'u yoksa satıcıdan istenir; beklerken CNC PC'deki kurulu yazılım listesine ve hareket kartının firmware bilgisine bakılır. Component X kontrol yazılımının içinde geliyorsa şart sağlanır.
- **Sürüm etkileniyor mu?** Makinedeki sürüm 2.4; CVE kaydındaki etkilenen sürüm aralığıyla karşılaştırılır. 2.4 bu aralıktaysa şart sağlanır.
- **Açık ulaşılabilir mi?** CVSS 9.8 genellikle ağ üzerinden, kimlik doğrulama olmadan istismar anlamına gelir. CNC PC atölye ağına ve uzak servis bağlantısına açıksa açık ulaşılabilirdir. CNC PC hiçbir ağa bağlı değilse ve USB kapalıysa ulaşılabilirlik düşer.

Sonuç: Üç şart birlikte sağlanıyorsa CVE bu makineyi gerçekten etkiler. Biri bile sağlanmıyorsa kayıt "etkilenmiyor" gerekçesiyle kapatılır ve gerekçe saklanır.

2 **Üretimi hemen durdurur musunuz? Neden / neden değil?**

Hayır, otomatik olarak durdurmam; önce açığa giden yolu kapatırım. CVE, CNC kontrol yazılımını etkiliyor; makineyi yanlış çalıştırabilir ama emniyet fonksiyonları (acil durdurma, Z freni, kişi algılama) emniyet rölesi üzerinden donanımsal çalışıyorsa insanı korumaya devam eder. Bu yüzden hemen CNC PC'nin ağ bağlantısı kesilir, uzak erişim kapatılır ve USB girişleri engellenir; üretim bu şekilde sürebilir.

- **Durdururum, eğer:** açığın aktif olarak istismar edildiğine dair işaret varsa (beklenmeyen parametre değişikliği, tanımadık bağlantı) ya da acil stop yalnızca CNC kartı üzerinden çalışıyorsa. Bu durumda yazılımdaki açık doğrudan emniyeti etkiler.

3 **Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?**

Önce test. Yama, eksen hareketini yöneten yazılımı değiştirir; test edilmeden uygulanırsa makine beklenmedik şekilde hareket edebilir.

- **Nerede:** Varsa aynı sürüme sahip yedek kontrol bilgisayarı ve hareket kartından oluşan bir test düzeneğinde. Yoksa makinenin kendisinde, üretim dışı planlı bir bakım penceresinde, tabla boşken.
- **Öncesinde:** CNC yazılım ayarlarının, servo sürücü ve inverter parametrelerinin tam yedeği alınır; satıcıdan yamanın uyumluluk onayı istenir; geri dönüş planı hazırlanır.
- **Test:** Eksenlerin referansa gitmesi, yazılım limitleri, boşta deneme programı, ardından hurda levhada deneme kesimi ve acil stop testi.

---

4 **Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?**

Yama yalnızca CNC kontrol yazılımını değiştiriyorsa ve emniyet zinciri bu yazılımdan bağımsızsa **emniyet doğrulamasını doğrudan etkilemez**. Yama emniyet rölesine / Safety PLC'ye, servo sürücülerin STO veya fren fonksiyonuna ya da acil stop'un işlendiği bir girişe dokunuyorsa **etkiler** ve ilgili emniyet fonksiyonları yeniden doğrulanır. Nasıl anlaşılır:

- Yama notları ve satıcının etki analizi incelenir: hangi bileşenler ve fonksiyonlar değişiyor?
- Yama öncesi ve sonrası servo sürücü, inverter ve emniyet konfigürasyonu karşılaştırılır; emniyet konfigürasyonunun sağlama toplamı değişmişse doğrulama zorunludur.
- Değişmemiş görünse bile yamadan sonra acil stop, Z freni ve spindle duruş süresi fonksiyon testleri yapılır ve kayda geçer.

---

5 **Yama mümkün değilse compensating control (telafi edici önlem) ne olur?**

- CNC PC internetten ve ofis ağından tamamen ayrılır; G-kodu yalnızca tek yönlü, kontrollü bir klasörden alınır.
- Açığın kullandığı ağ servisi / portu güvenlik duvarında kapatılır.
- Uzak erişim varsayılan olarak kapalı tutulur; yalnızca onayla, kayıt altında ve kısa süreli açılır.
- USB girişleri kapatılır, CNC PC'de yalnızca onaylı uygulamaların çalışmasına izin verilir.
- Parametre değişiklikleri ve bağlantılar izlenir; düzenli olarak referans yedekle karşılaştırılır.
- Acil stop ve Z freni testleri sıklaştırılır.
- Karar, gerekçesi ve yamanın uygulanacağı hedef tarihle birlikte zafiyet kaydına yazılır.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.

Kaynaklar: IEC 62443-2-3 (OT ortamında yama yönetimi) · IEC 62443-3-3 · EN ISO 13849-2 (doğrulama) · EU 2024/2847 Siber Dayanıklılık Yasası (CRA).